

PLATAFORMA DE TARJETAS MÉXICO

Plan de remediación de los pendientes estructurales

Cierre de las brechas de la auditoría PCI (DSS v4.0 / PIN v3.1) que ya no son de código sino de **infraestructura, hardware o proceso regulatorio**. Los hallazgos de software del CMS ya se remediaron y desplegaron; aquí quedan los que requieren compra, decisiones de plataforma o coordinación con áreas externas.

FECHA	CERRADOS (CÓDIGO)	PENDIENTES	ESTÁNDARES
16 sep 2026	13 hallazgos	5 estructurales	PCI DSS v4.0 · PIN v3.1



Ya remediado y desplegado (no requiere acción)

Cerrado en código durante esta ronda, de forma reversible y verificado en el servidor:

- A1 test-secrets
- A2 SAD en logs
- A3 MFA consola*
- A4 anti-bot + rate-limit
- A6 HSM falso retirado
- A7 bitácora hash+inmutable
- A8 TLS 8583 forzado
- M1 fuga de errores
- M2 TLS en tránsito
- M3 HSTS/CSP
- M4 rotación llave PAN
- M5 pass BD
- M6 política contraseñas

* A3 MFA quedó implementado en el CMS con el interruptor apagado; su activación es un paso operativo (ver Fase 1).

Resumen priorizado

#	PENDIENTE	ESTÁNDAR	PRIORIDAD	ESFUERZO	RESPONSABLE
E1	HSM certificado (PCI HSM / FIPS 140-2 N3) + ceremonia de llaves	PCI PIN 1/5/18/30	Alta	Grande	Infra/Seguridad + proveedor
E2	Bitácora: dueño separado + WORM/SIEM + retención 12 meses	PCI DSS 10.5/10.7	Alta	Media	DBA + Plataforma
E3	Cifrado en reposo de la BD + respaldos cifrados + DR	PCI DSS 3.5/9.4/12.10	Alta	Media	Infraestructura
E4	Reportes regulatorios: formato y canal oficial + sello externo	UIF/CNBV/Banxico	Media	Grande	Cumplimiento + Dev
E5	Centralizar MFA en el IAM (WebAuthn) + códigos de recuperación	PCI DSS 8.4/8.5	Media	Media	Equipo IAM

Esfuerzo orientativo: Pequeño ≤1 sem · Media 2–4 sem · Grande >1 mes (incluye compra/regulatorio).

Detalle por pendiente

E1

HSM certificado y gestión de llaves

Alta

Hoy: la criptografía de PIN/CVV/ARQC corre contra **PayShieldSim** (simulador), con llaves de laboratorio sin ceremonia ni bloques de llave. El código ya está listo para un HSM real (comandos payShield BA/DG/EA/CW/CY/KQ); solo falta el hardware certificado y el proceso de llaves.

Riesgo: ninguna transacción con PIN puede considerarse conforme sobre un HSM simulado. Es el bloqueante principal para operar con dinero real.

Qué falta

Adquirir/contratar un **PCI HSM (payShield 10K)** o HSM-as-a-service con AOC; migrar los blobs a la LMK real; ceremonia de llaves con custodios y bajo doble control; bloques de llave **TR-31** en vez de variantes; rotación con criptoperiodos.

Estándar

PCI PIN v3.1 Req 1, 5–18 (gestión de llaves), 30 (HSM certificado).

Dependencias

Compra/contrato; ventana de red al HSM; definir custodios; ZPK de zona compartida con el adquirente.

Responsable

Infraestructura/Seguridad + proveedor de HSM; apoyo de Dev para el corte.

Verificación

KCV de cada llave desde el HSM; prueba on-us RC 00/55 contra el HSM real; evidencia de la ceremonia.

E2 Bitácora de auditoría: inmutabilidad plena

Alta

Hoy: ya hay **tamper-evidence** (cadena de hash con verificación) y **tamper-prevention** a nivel de BD (trigger que bloquea UPDATE/DELETE). Falta el cierre pleno de retención y separación de roles.

Qué falta	Que el rol de la app tenga solo INSERT/SELECT sobre <code>audit_logs</code> (dueño de la tabla distinto, para que ni con las credenciales de la app se pueda alterar/borrar ni quitar el trigger); export append-only a WORM/SIEM ; retención de 12 meses (3 en línea) con purga controlada.
Estándar	PCI DSS v4.0 Req 10.5.1 (retención), 10.5/10.7 (protección e integridad), 10.3.2.
Dependencias	Rol de BD dedicado (dueño ≠ app); destino SIEM/WORM; job/procedimiento de purga privilegiada.
Responsable	DBA + Plataforma.
Verificación	La app no puede UPDATE/DELETE ni DROP del trigger; export verificable; política de retención documentada.

E3 Cifrado en reposo, respaldos y DR

Alta

Hoy: el PAN se cifra a nivel de aplicación (AES-256-GCM con rotación de llave) y el secreto TOTP también. Falta cerrar el cifrado del **medio** y la continuidad.

Qué falta	Cifrado en reposo del volumen/instancia PostgreSQL ; respaldos cifrados con prueba de restauración periódica; plan de DR documentado y probado (RTO/RPO).
Estándar	PCI DSS v4.0 Req 3.5 (medios), 9.4 (respaldos), 12.10 (continuidad).
Dependencias	Capacidad del hipervisor/almacenamiento (LUKS/cloud KMS); ventana para cifrar; gestión de llaves del respaldo.
Responsable	Infraestructura.
Verificación	Evidencia de cifrado del volumen; restauración exitosa de un respaldo cifrado; simulacro de DR.

E4 Reportes regulatorios: formato y canal oficial

Media

Hoy: los reportes (PLD/UIF, R24 Banxico, conciliación, disputas) **ya consultan datos reales** y se sellan con SHA-256; producen CSV interno. Falta el formato/entrega oficial y un sello no auto-referencial.

Qué falta	Layouts oficiales validados con Cumplimiento; canal de presentación a UIF/CNBV/Banxico (SITI/RegTech según aplique); sello de integridad externo (firma/WORM), no guardado junto al dato.
Estándar	Marco MX: Banxico Circular 4/2014, Disposiciones CNBV, PLD/UIF, CONDUSEF.
Dependencias	Definición regulatoria por Cumplimiento; credenciales/portales de envío; calendario de reporte.
Responsable	Cumplimiento (define) + Dev (implementa).
Verificación	Un reporte aceptado por cada autoridad en su formato; sello verificable de forma independiente.

E5 MFA centralizado en el IAM

Media

Hoy: el segundo factor (TOTP) está **implementado en el CMS** (apagado hasta activarlo). Lo ideal es que viva en el IAM corporativo para cubrir a todas las plataformas de forma homogénea.

Qué falta	MFA en el IAM (TOTP y/o WebAuthn/passkeys) para el proyecto <code>EMISION_CMS</code> ; códigos de recuperación ; que el CMS exija el claim de "MFA satisfecho" del token en vez de su propio segundo factor.
Estándar	PCI DSS v4.0 Req 8.4.2 / 8.5 (MFA para todo acceso al CDE).
Dependencias	Roadmap del equipo del IAM; despliegue del IAM; enrolamiento de usuarios.
Responsable	Equipo IAM; Dev del CMS para el corte al claim.
Verificación	Login del CDE exige segundo factor vía IAM; el CMS rechaza tokens sin MFA.

Hoja de ruta sugerida

Secuencia por dependencia y valor. Las activaciones operativas (sin compra) van primero.

Fase 0 ahora

Activaciones operativas (sin costo, ya implementado): encender **MFA** en el CMS con un usuario de prueba y luego para todos; correr el CMS con perfil `prod` para que el guard de **TLS 8583** aplique; confirmar TLS del proxy de borde con un escáner externo. Coordinar con dlugo para que sus redeployes no reviertan PIN/TLS/overrides.

Fase 1 2–4 sem

E2 (bitácora: rol dueño separado, export a SIEM, retención 12 meses) y **E3** (cifrado en reposo + respaldos cifrados + simulacro DR). Son de plataforma/DBA, sin compra mayor, y cierran controles de alto peso (Req 10 y 3/9/12).

Fase 2 1–2 meses

E1 (HSM certificado + ceremonia de llaves): iniciar la compra/contrato en paralelo desde ya por el plazo de aprovisionamiento; es el bloqueante para producción con dinero real. **E5** (MFA en el IAM) si el equipo del IAM lo prioriza.

Anexo — detalle de lo ya remediado (código)

Cada uno cerrado en código, desplegado de forma reversible (imagen de respaldo por cambio) y verificado en el servidor interno. Referencia técnica y evidencia en el repositorio.

A1 Endpoint `test-secrets` bloqueado

Era Alta

Era: GET `/api/cards/{id}/test-secrets` devolvía PAN + PIN + CVV/CVV2/iCVV + track2 en claro, protegido solo por un flag (activo para la demo) y con el permiso más bajo.

Se hizo: bloqueo duro en perfil `prod` (responde 404 aunque el flag esté activo); no depende solo del flag. En dev/demo sigue disponible para las herramientas de prueba.

Verificado: con perfil `prod` el endpoint no existe; en demo devuelve los datos de prueba.

A2 SAD fuera de bitácoras y del ledger

Era Alta

Era: el PIN block, PVV y CVV2 se registraban a nivel INFO y el PIN block cifrado se guardaba en la descripción del asiento contable.

Se hizo: se eliminaron PIN/PVV/CVV de todos los logs y de la descripción del ledger; se sanitizó el log del HSM (ya no vuelca la respuesta cruda).

Verificado: 0 ocurrencias de PIN/PVV/CVV en las bitácoras de emisión.

A3 MFA (TOTP) en la consola *

Era Alta

Era: la consola que administra el CDE entraba solo con usuario + contraseña, sin segundo factor.

Se hizo: MFA TOTP (RFC 6238, compatible con Google Authenticator) en el login del CMS; el secreto se guarda cifrado (AES-GCM); alta con secreto/URI otpauth; tabla creada por Flyway (V2). Endpoints `/api/auth/mfa/enable` y `/verify`.

Verificado: algoritmo probado con los vectores oficiales RFC 6238; endpoints activos. * **Interruptor apagado por defecto** (`CMS_MFA_ENABLED`): su activación para todos los usuarios es un paso operativo (Fase 0). Ideal a futuro: centralizarlo en el IAM (E5).

A4

Anti-bot honesto + bloqueo por intentos

Era Alta

Era: el "reCAPTCHA v2" del login era un reto de solo-cliente con insignia engañosa ("reCAPTCHA v2 / PCI Security Pass"), y no había límite de intentos en el servidor.

Se hizo: etiqueta honesta ("Verificación anti-bot / Finsus Security") y **bloqueo por intentos por usuario** en `/api/auth/login` (429 tras 5 fallos en 15 min), además del bloqueo del IAM.

Verificado: 5 intentos → 401, 6° → 429.

A6

HSM falso retirado

Era Alta

Era: un `HsmService` heredado fabricaba PVV/CVV con `Math.random()` y un inventario de llaves con blobs hardcodeados.

Se hizo: se eliminó por completo; el controlador de HSM ahora usa el HSM real (`CardCryptoService` / `PayShield`): `/status` con salud real, `/keys` con referencias de llaves configuradas (sin blobs/KCV falsos), `/card/{id}` sin datos sensibles; se retiró `/crypto/generate`. La personalización de plásticos usa solo la cripto real.

Verificado: suite de pruebas en verde; endpoints reales. Residual: usar un HSM certificado (E1).

A7

Bitácora con hash encadenado e inmutable

Era Alta

Era: la bitácora de auditoría era una tabla mutable, sin integridad ni protección: cualquiera con acceso a la BD podía alterar o borrar filas sin detección.

Se hizo: **tamper-evidence** (cada registro encadena el hash del anterior; `GET /api/audit/verify` detecta manipulación y señala el id) + **tamper-prevention** (trigger en la BD que bloquea UPDATE/DELETE).

Verificado: alterar un registro → `ok=false` con el id; revertir → `ok=true`; UPDATE y DELETE rechazados por la BD. Residual: dueño de tabla separado + WORM + retención 12 meses (E2).

A8

TLS forzado en el canal 8583

Era Alta

Era: el listener ISO 8583 (transporta PAN y el bloque de PIN) podía arrancar en TCP plano por defecto.

Se hizo: guard de arranque — en perfil `prod` el CMS **no arranca** si el 8583 no tiene TLS + TLS mutuo + allowlist; y el socket solo habilita **TLS 1.2/1.3**.

Verificado: con prod + TLS apagado el arranque aborta; en el servidor corre con TLS 1.3 + mTLS.

M1 Sin fuga de detalles en errores

Era Media

Era: el manejador global devolvía al cliente `ex.toString()` ("temporary for debugging"), exponiendo internos.

Se hizo: el cliente recibe un mensaje genérico + `traceId` ; el detalle solo va al log del servidor.

M2 TLS en tránsito reconocido por la app

Era Media

Era: detrás del proxy que termina TLS, la app veía todo como HTTP y no emitía HSTS.

Se hizo: `forward-headers-strategy=framework` (la app reconoce HTTPS y emite HSTS) y el nginx de la consola preserva `X-Forwarded-Proto` .

Verificado: el borde sirve TLS 1.3 con cert Let's Encrypt válido; HSTS presente en `/api` . Residual: TLS extremo a extremo en los saltos internos.

M3 Cabeceras de seguridad (HSTS/CSP)

Era Media

Era: la consola no enviaba HSTS, CSP ni cabeceras anti-clickjacking/sniffing.

Se hizo: HSTS, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options y Referrer-Policy, tanto en la app como en el nginx de la consola.

Verificado: cabeceras presentes en el documento y en `/api` . La CSP tolera el inline de la SPA; endurecerla con nonces es un paso posterior.

M4 Rotación de la llave de la bóveda de PAN

Era Media

Era: el PAN se cifraba con una única llave estática, sin versión ni proceso de rotación.

Se hizo: registro de llaves con id embebido en el ciphertext (`k<id>:`); las filas antiguas siguen legibles; endpoints ADMIN de estado y de re-cifrado (`/api/cards/pan/rotate`).

Verificado: rotación real en el servidor (todas las tarjetas re-cifradas a la llave nueva) y cobro on-us OK bajo la llave rotada.

M5 Contraseña de BD sin default vacío

Era Media

Era: `DB_PASSWORD` tenía default vacío (podía conectar a una BD con auth 'trust' sin darse cuenta).

Se hizo: se quitó el default vacío (placeholder de sandbox evidente); en producción viene del `.env` . Nota pendiente: usuario de BD dedicado con privilegios mínimos (no `postgres`).

M6

Política de contraseñas alineada

Era Media

Era: el CMS validaba 10 caracteres y la doc decía 10, pero el IAM exige 12 — un cambio de clave con 10-11 se rechazaba.

Se hizo: alineado a **mínimo 12 caracteres** en backend, consola y documentación. La complejidad/historial la aplica el IAM.

Alcance. Este plan cubre los pendientes de la auditoría interna del CMS emisor que no son de código. Los 13 hallazgos de software ya fueron remediados, desplegados de forma reversible y verificados en el servidor interno; el detalle técnico y la evidencia están en el repositorio ([docs/](#)) y en los informes de traza/PIN.

Documento de uso interno — plataforma de tarjetas México, 16 sep 2026. Los esfuerzos son estimaciones de planeación, no compromisos; confirmense con cada área responsable.